

Case Study

Case: SOC342 - CVE-2025-53770 SharePoint ToolShell Auth Bypass and RCE

Executive Summary

Investigated a critical unauthenticated remote code execution (RCE) attack targeting the on-premises SharePoint server **SharePoint01** (172.16.20.17) via CVE-2025-53770 (ToolShell). The attacker successfully bypassed authentication, extracted the ASP.NET MachineKey, deployed a malicious web shell (`spinstall0.aspx`), and established outbound C2 communications. The attack was detected by SOC rule **SOC342** at **01:07 PM** on **July 22, 2025**, and the host was contained shortly after detection.

The vulnerability has a **CVSS score of 9.8** and was actively exploited in the wild by multiple threat actor clusters, including activity linked to IP `107.191.58[.]76`.

Timeline

01:07:11 PM: Exploit initiated via **SharePoint RCE** over port 80; (`w3wp.exe` (PID: 4560, User: IIS APPPOOL\SharePoint - 80) spawned an unauthorized `powershell.exe` executing a Base64 encoded payload to extract critical `MachineKey` parameters (`ValidationKey``DecryptionKey`) via memory reflection)

01:07:24 PM: Execution phase; `w3wp.exe` spawned an unauthorized `powershell.exe` (PID: 9876) utilizing evasion switches (`-nop -w hidden`) to execute the previously identified Base64 encoded `MachineKey` exfiltration payload.

01:07:27 PM: Payload compilation phase; `powershell.exe` invoked the .NET compiler `csc.exe` (PID: 9901) to compile a malicious source file (`payload.cs`) into an executable (`payload.exe`) inside the `C:\Windows\Temp\` directory.

01:07:29 PM: Persistence phase; `csc.exe` spawned `cmd.exe` (PID: 9910) to drop a persistent WebShell via string redirection (`echo <WebShell> > ...`) into the SharePoint public web directory.

01:07:34 PM: Validation phase; `cmd.exe` spawned `powershell.exe` (PID: 9920) to directly execute unencoded commands extracting the SharePoint `MachineKeySection` configuration from the server's running assembly memory.

01:07:35 PM: Exfiltration phase; the compromised process initiated an outbound Command and Control (C2) `107.191.58[.]76` network connection over the internet to exfiltrate the stolen `MachineKey` tokens and establish remote access.

01:15:00 PM: Containment initiated; The compromised SharePoint server was network-isolated by dropping all inbound and outbound traffic at the firewall level.

01:18:00 PM: Containment complete; Host isolation verified; all active Command and Control (C2) beaconing loops broken.

Investigation Steps

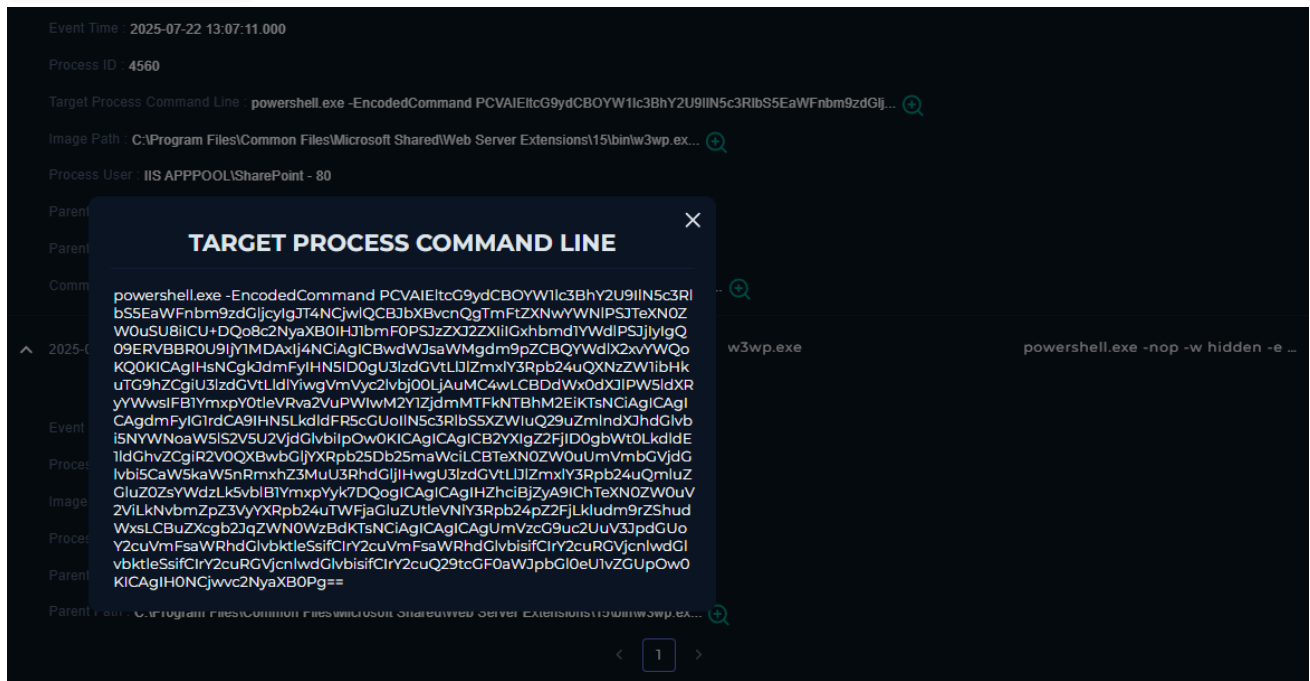
1. Reviewed Security Information and Event Management (SIEM) / Process Logs

Analyzed host process creation logs to map out the standard system boot baseline up to the initialization of the IIS application pool helper service (AppHostSvc).



2. Identified Initial Access Vector (SharePoint RCE)

Detected an abnormal child process creation where the IIS Worker Process `w3wp.exe` (PID: 4560) running under `IIS APPPOOL\SharePoint - 80` spawned an unauthorized `powershell.exe` instance over HTTP/Port 80

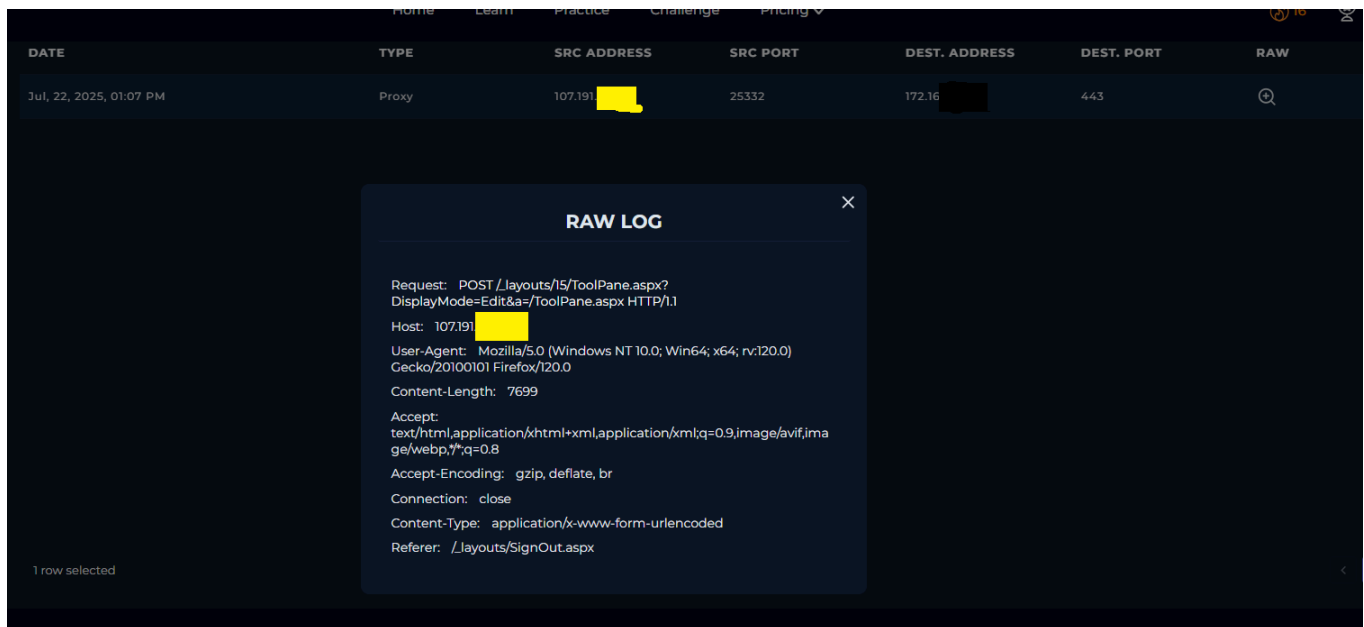


3. Decoded Malicious Encoded Payloads

Extracted the Base64 command-line string from the compromised PowerShell process and decoded it to reveal a malicious C# script targeting the .NET MachineKeySection

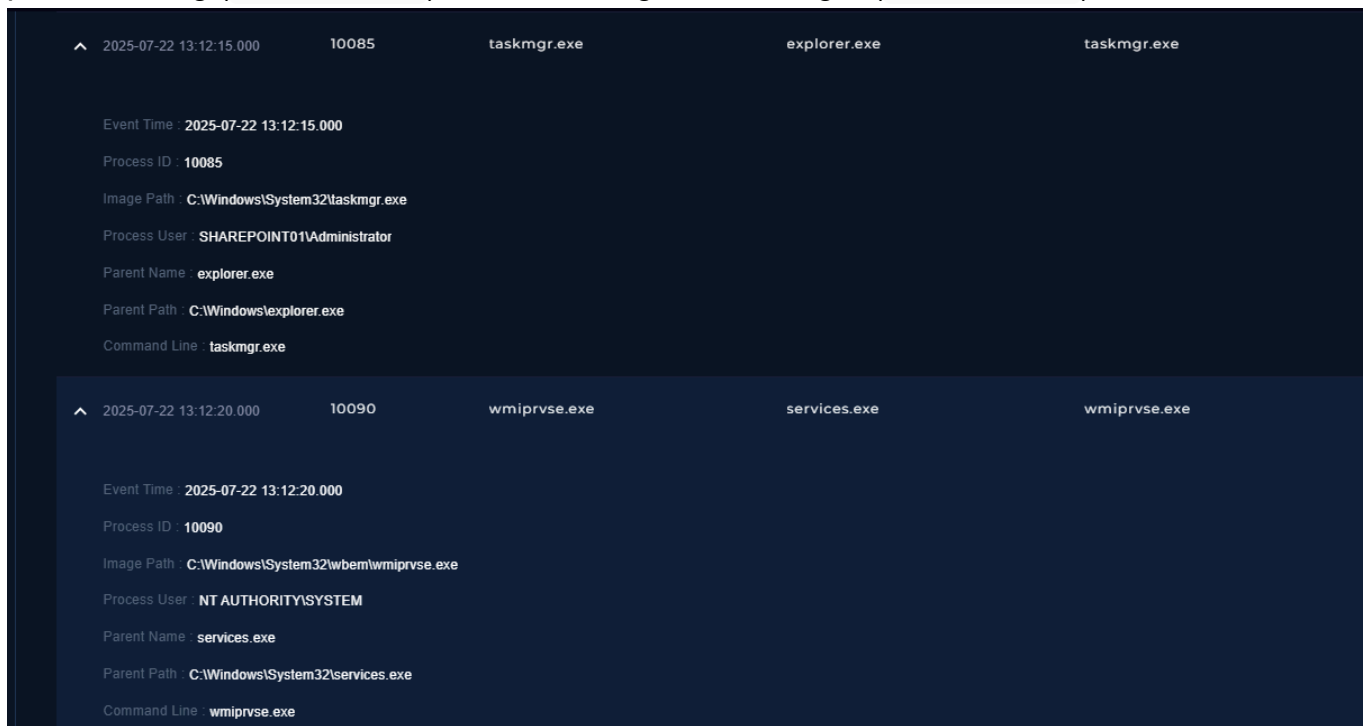


Figure 1. The effect of the number of trials on the number of correct responses. The number of correct responses was significantly higher for the 10-trial condition than for the 5-trial condition. Error bars represent the standard error of the mean.



6. Audited Incident Response and Administrative Actions

Traced the system administrator's interactive logon session via `explorer.exe` at 01:11 PM, confirming the manual triage steps including directory auditing (`dir C:\Windows\Temp`), process listing (`Get-Process`), and launching Task Manager (`taskmgr.exe`).



Indicators of Compromise (IOCs)

Type	Value	Description
IP Address	107.191.x.x	Attacker infrastructure / Command and Control (C2) source IP.
IP Address	172.16.20.x	Internal compromised SharePoint host destination IP.

Type	Value	Description
URI Path	/_layouts/15/ToolPane.aspx	Malicious URI endpoint targeted to execute the SharePoint RCE.
File Path	C:\Windows\Temp\payload.cs	Malicious source code file dropped during the compilation phase.
File Path	C:\Windows\Temp\payload.exe	Compiled malicious binary executable generated via <code>csc.exe</code> .
Process Name	powershell.exe	Misused system binary executed with <code>-nop -w hidden -EncodedCommand</code> switches

MITRE ATT&CK Mapping

- **T1190:** Exploit Public-Facing Application
- **T1059.001:** Command and Scripting Interpreter: PowerShell
- **T1204.002:** User Execution: Malicious File
- **T1027:** Obfuscated Files or Information
- **T1003:** OS Credential Dumping
- **T1505.003:** Server Software Component: Web Shell
- **T1071.001:** Application Layer Protocol: Web Protocols

Containment Actions

1. **Host Isolation

Isolated the compromised SharePoint server (`172.16.x.x`) from the network by blocking all inbound and outbound traffic at the firewall level to sever the active C2 connection with `107.191.x.x`.

2. **Process Termination

Terminated the compromised IIS Worker Process `w3wp.exe` (PID: 4560) and killed all active spawned child processes including `powershell.exe`, `csc.exe`, and `cmd.exe` to stop unauthorized memory reflection and code execution.

3. **Service Suspension

Stopped the World Wide Web Publishing Service (`w3svc`) and Application Host Helper Service (`AppHostSvc`) immediately to take the vulnerable SharePoint portal offline and prevent further inbound exploitation attempts.

4. Credential Revocation & Key Invalidation

Invalidated the leaked Microsoft .NET `MachineKey` parameters (`ValidationKey` and `DecryptionKey`) to prevent the attacker from forging valid session authentication tokens (ViewState Deserialization attacks).

Lessons Learned

1. Patch Management Criticality:

Maintaining an outdated SharePoint v15 instance exposed the infrastructure to known Remote Code Execution (RCE) vulnerabilities. Vulnerable public-facing servers must be prioritized for immediate security patching and regular update cycles.

2. The Danger of Hardcoded or Exposed MachineKeys:

Leaving static `.NET MachineKey` parameters (`ValidationKey` / `DecryptionKey`) unchanged allows attackers to maintain stealthy persistence via ViewState Deserialization. These keys must be periodically rotated and dynamically generated.

3. Insufficient Endpoint Hardening:

The web server daemon (`w3wp.exe`) should never be allowed to spawn system binaries like `powershell.exe` or compilers like `csc.exe`. Implementing strict Attack Surface Reduction (ASR) rules would have blocked this process lineage immediately.

4. Lack of Strict Egress Filtering:

The server allowed an unrestricted outbound C2 connection to an external IP (`107.191.x.x`) over port 443. Implementing strict egress network policies would have contained the data exfiltration phase.

5. Inadequate Directory Monitoring:

The creation of unauthorized binaries (`payload.exe`) within `C:\Windows\Temp\` and the dropping of a WebShell went unblocked. File Integrity Monitoring (FIM) should be deployed to alert on any modifications within public web directories.

Recommendations

- **Patch & Update:** Immediately update the SharePoint server to plug the RCE vulnerability.
 - **Rotate MachineKeys:** Generate new `.NET ValidationKey` and `DecryptionKey` parameters immediately.
 - **Process Hardening:** Deploy EDR/ASR rules to block `w3wp.exe` from spawning `powershell.exe` or `csc.exe`.
 - **Network Egress Filtering:** Restrict outbound server connections to authorized destinations only.
 - **Directory Lockdown:** Implement File Integrity Monitoring (FIM) on public web and `Temp` directories.
-